

Windows Server Hardening Checklist

Table of Contents

Intro 3

Configuration Management 3

Windows Server Preparation 4

Windows Server Installation 4

User Account Security Hardening 5

Network Security Configuration and Access Management 6

Registry Security Configuration 7

General Security Settings 8

Audit Policy and Advanced Audit Policy Configuration 9

Brief Guide to Additional Hardening 9

How Netwrix Can Help 10

Intro

Deploying servers in their default state is the quickest way to get the job done. But the server will almost certainly be optimized for ease of use, often at the expense of cyber security. By investing a little time in Windows Server hardening — identifying and remediating security vulnerabilities that threat actors could exploit — you can dramatically reduce your risk of costly breaches and business disruptions from attacks, malware (including ransomware), and other cyber threats.

This guide provides a comprehensive checklist of Windows Server hardening best practices for strengthening your security and compliance posture and protecting your vital systems and data. Your goal should be to establish security baselines tailored for your environment that reduce your attack surface and improve information security. You can get additional guidance from the [Center for Internet Security \(CIS\)](#) and the [US Department of Defense Security Technical Implementation Guide \(STIG\)](#).

Keep in mind that although server hardening is vital to cybersecurity, you also need to implement appropriate controls and processes, increase security awareness across the enterprise and follow other critical data security best practices.

Configuration Management

Before diving into detailed secure configuration guidance, it's worth reviewing some broader security best practices for developing, documenting and managing your configurations:

- Maintain an inventory record for each server that clearly documents its baseline configuration and records every change to the server.
- Review and minimize the applications installed on each server to reduce risk.
- Thoroughly test and validate every proposed change to server hardware or software before making the change in the production environment.
- Regularly perform a [risk assessment](#). Use the results to update your risk management plan and maintain a prioritized list of all servers to ensure that security vulnerabilities are fixed in a timely manner.
- Keep all servers at the same revision level to simplify configuration management.

Windows Server Preparation

- Protect new servers from potentially hostile network traffic until the operating system is fully hardened. Harden new servers in a network that is not open to the internet.
- Set a strong BIOS/firmware password to prevent unauthorized changes to the server's settings.
- Disable automatic administrative logon to the recovery console.
- Configure the device boot order to prevent unauthorized booting from alternate media.

Windows Server Installation

- Ensure that the system does not shut down during installation.
- Create a system configuration based on the specific role that is needed. You can use the Security Configuration Wizard for this purpose.
- When you install Windows Server, immediately update it with the latest patches using WSUS or SCCM. Security patches resolve known vulnerabilities that attackers could otherwise exploit to compromise a system.
- Enable automatic notification of patch availability and make sure that all appropriate patches, hotfixes and service packs are reviewed, tested and applied in a timely manner.

User Account Security Hardening

- Disable and rename the guest account on each server.
- Disable and rename the local Administrator account on any machine that is part of a domain where uniquely named domain admin accounts will be used.
- Minimize access to privileged functions. Pay special attention to rights granted to built-in accounts and groups such as:
 - Local System (NT AUTHORITY\System)
 - Network Service (NT AUTHORITY\NetworkService)
 - Administrators group
 - Backup Operators group
 - Users group
 - Everyone group

For example, by default, the 'Access this computer from the network' right is granted to the Everyone group, essentially giving all users unrestricted remote access to shared folders.

- Ensure that passwords of system and administrator accounts [meet password best practices](#). In particular, verify that these privileged account passwords are not based on a dictionary word and are at least 15 characters long, with letters, numbers, special characters and invisible (CTRL ^) characters interspersed throughout. Ensure that your strong password policy requires passwords to be changed every 90 days.
- Configure account lockout Group Policy according to [account lockout best practices](#).
- Disallow users from creating and logging in with Microsoft accounts.
- Do not allow "everyone" permissions to apply to anonymous users.
- Disallow anonymous enumeration of SAM accounts and shares.
- Disable anonymous SID/Name translation.
- Promptly disable or delete unused user accounts

Network Security Configuration and Access Management

- Enable the Windows firewall and make sure the Firewall is enabled for each of the Domain, Private and Public firewall Profiles. Configure the default behaviour of the Firewall for each Profile to block inbound traffic by default.
- Where inbound access is required to a server, restrict it to necessary protocols, ports and IP addresses.
- Perform port blocking at the network setting level. Perform an analysis to determine which network ports need to be open and restrict access to all other ports.
- Allow only Authenticated Users to access any computer from the network.
- Do not grant any users the 'act as part of the operating system' right.
- Deny guest accounts the ability to log on as a service, as a batch job, locally or via RDP.
- If RDP is used, set the RDP connection encryption level to high.
- Remove Enable LMhosts lookup.
- Disable NetBIOS over TCP/IP.
- Remove ncacn_ip_tcp.
- Configure both the Microsoft Network Client and the Microsoft Network Server to always digitally sign communications.
- Disable the sending of unencrypted passwords to third-party Server Message Block (SMB) servers.
- Do not allow any shares to be accessed anonymously.
- Set up the LAN Manager to refuse LM and NTLMv1 authentication.
- Allow Local System to use computer identity for NTLMv2 authentication.
- Disable Local System NULL session fallback.
- Configure allowable encryption types for Kerberos authentication.

- Do not store LAN Manager hash values.
- Remove file and print sharing from network settings. File and print sharing could allow anyone to connect to a server and access critical data without requiring a user ID or password.

Registry Security Configuration

Ensure that all administrators take the time to thoroughly understand how the registry functions and the purpose of each of its keys. Many of the vulnerabilities in the Windows operating system can be mitigated by changing the following keys:

- Protect the registry from anonymous access.
- Disallow remote registry access if not required.
- Set MaxCachedSockets (REG_DWORD) to 0.
- Set SmbDeviceEnabled (REG_DWORD) to 0.
- Set AutoShareServer to 0.
- Set AutoShareWks to 0.
- Delete all values in the NullSessionPipes key.
- Delete all values in the NullSessionShares key.

General Security Settings

- Disable any unneeded services included in the default installation to reduce the server's vulnerability. See the Netwrix® [Hardened Services Guide](#) for specific guidance.
- Remove unnecessary Windows Server roles and features.
- Enable the built-in Encrypting File System (EFS) with NTFS or BitLocker.
- If the server has significant random access memory (RAM), disable the Windows swapfile. This will improve performance and make the machine more secure because no sensitive data can be written to the hard drive.
- Do not use AUTORUN. Otherwise, untrusted code can be run without the direct knowledge of the user; for example, attackers might put a CD into the machine and cause their own script to run.
- Display a legal notice like the following before the user logs in: "Unauthorized use of this computer and networking resources is prohibited..."
- Require Ctrl+Alt+Del for interactive logins, and configure an inactivity limit to terminate idle interactive sessions.
- Ensure all volumes are using the NTFS file system.
- Configure Local file and folder permissions. By default, Windows does not apply specific restrictions on any local files or folders; the Everyone group is given full permissions to most of the machine. Remove this group and instead grant access to files and folders using role-based groups based on the least-privilege principle. Every attempt should be made to remove Guest, Everyone and ANONYMOUS LOGON from user rights.
- Set the system date/time and configure it to synchronize against domain time servers.
- Configure a timeout that locks the console's screen automatically if it is left unattended.

Audit Policy and Advanced Audit Policy Configuration

- Create an audit policy according to [audit policy best practices](#) to define which events are written to the security logs to gain visibility into critical activity.
- Configure the event log retention method to overwrite as needed and make sure up to 4GB of storage is reserved.
- Configure security log shipping to your security information and event management (SIEM) tool, if you have one, to improve threat detection and response.

Brief Guide to Additional Hardening

The settings below can be defined locally using the Windows Local Security Policy editor or the Local Group Policy editor. Alternatively, in a domain environment, use the Active Directory GPO (Group Policy Object) Management features on your domain controller to create centralized configuration policies to deploy to all member computers.

- Rigorously enforce the least privilege principle to limit user rights. The **User Rights Assignment** settings control the permissions and access to privileged functions on a per user and per group basis. Windows has a number of built in user accounts and groups, otherwise known as Special Identities, with relevant privileges aligned to them; they include:
 - Local System, or NT AUTHORITY\System
 - Network Service, or NT AUTHORITY\NetworkService,
 - Administrators group
 - Backup Operators group
 - Users
 - Everyone

It is vital to minimize the assignment of built-in groups and accounts to these user rights. For example, the 'Access this computer from the network' setting is set by default to 'Administrators, Backup Operators, Everyone, Users' on Windows 10 — essentially granting unrestricted remote access to shared folders for all users. To reduce this security risk, the recommended setting is to restrict these rights to just the Administrators and Remote Desktop User groups to improve access control.

- Install and enable anti-virus software. Configure it to scan all downloads and attachments and to provide real-time protection. Set to update daily.
- Install and enable anti-spyware software. Configure it to update daily.
- Install and enable data loss prevention (DLP) software.
- Promptly review, test and install recommended updates and patches for all operating system and applications to promptly patch vulnerabilities and improve application security.
- Follow security best practices, as well as database hardening and application hardening guidance, for all your systems.

How Netwrix® Can Help

[Netwrix Change Tracker](#) simplifies Windows Server hardening and configuration management. It uses system and file integrity monitoring technology to analyze configuration settings and pinpoint vulnerabilities and errors, and provides detailed guidance for establishing a hardened baseline configuration. Then it help you maintain those secure configurations by monitoring and alerting on suspicious changes to:

- Filesystem
- Registry
- Windows Security and Audit policy
- Installed software
- Local user groups and accounts

- Open network ports
- Service states and running processes

Any drift from the hardened configuration can be corrected immediately, while any unexpected change can be promptly investigated to prevent security breaches and downtime. Integration with your overall security system can be provided, either as a component of a 3rd party managed security service or for an in-house approach.

Harden Windows Server configurations with Netwrix Change Tracker

- Establish strong Windows Server configurations faster with hardened configuration templates.
- Quickly spot and correct any configuration drift.
- Monitor all changes to Windows Server configurations and get targeted alerts on unexpected modifications to avert security incidents and business downtime.
- Increase confidence in your security posture with comprehensive information on security status.
- Pass compliance audits with ease using 250+ CIS-certified reports covering NIST, PCI DSS, CMMC, STIG and NERC CIP.

[Request Free Trial](#)

About Netwrix

Netwrix makes data security easy thereby simplifying how professionals can control sensitive, regulated and business-critical data, regardless of where it resides. More than 11,500 organizations worldwide rely on Netwrix solutions to secure sensitive data, realize the full business value of enterprise content, pass compliance audits with less effort and expense, and increase the productivity of IT teams and knowledge workers.

Founded in 2006, Netwrix has earned more than 150 industry awards and been named to both the Inc. 5000 and Deloitte Technology Fast 500 lists of the fastest growing companies in the U.S.

For more information, visit www.netwrix.com

Next Steps

Netwrix products — Check out the full portfolio of Netwrix products: netwrix.com/products

Live demo — Take a product tour with a Netwrix expert: netwrix.com/livedemo

Request quote — Receive pricing information: netwrix.com/buy

CORPORATE HEADQUARTER:

300 Spectrum Center Drive
Suite 200 Irvine, CA 92618

565 Metro Place S, Suite 400
Dublin, OH 43017

5 New Street Square
London EC4A 3TW

PHONES:

1-949-407-5125
Toll-free (USA): 888-638-9749

1-201-490-8840

+44 (0) 203 588 3023

OTHER LOCATIONS:

Spain:	+34 911 982608
Netherlands:	+31 858 887 804
Sweden:	+46 8 525 03487
Switzerland:	+41 43 508 3472
France:	+33 9 75 18 11 19
Germany:	+49 711 899 89 187
Hong Kong:	+852 5808 1306
Italy:	+39 02 947 53539

SOCIAL:



netwrix.com/social